

PREGUNTAS	RESPUESTA	JUSTIFICACIÓN
¿Cuál de los siguientes es un ejemplo de fuente interna para definir requerimientos de seguridad?	Políticas de seguridad	Las políticas de seguridad son establecidas por una organización para proteger sus activos e información y son específicas para cada entidad. Las regulaciones, leyes y marcos legales son generalmente considerados fuentes externas, ya que son impuestos por entidades gubernamentales o reguladoras.
Cuando hablamos acerca de agentes de amenazas humanos, ¿Cómo se denomina a la gente que es un usuario común que tropieza con un error funcional en el software y que puede obtener acceso privilegiado a la información o la funcionalidad?	Descubridor Accidental	Este término sugiere que la persona no tiene la intención maliciosa de encontrar vulnerabilidades, pero accidentalmente descubre una y potencialmente puede explotarla sin darse cuenta del alcance de sus acciones.
Utilizar un mecanismos de autenticación único y centralizado que administra multifactor y control de acceso basado en roles. ¿Lo anterior es una técnica de mitigación para cual categoría de vulnerabilidades?	Broken Access Control	Esta medida se centra en fortalecer los métodos de autenticación y control de acceso para prevenir o mitigar los problemas relacionados con la identificación y autenticación de usuarios, lo que puede ayudar a reducir la exposición a posibles ataques que aprovechen estas vulnerabilidades.
Los beneficios de realizar análisis de código estático son que los errores y las vulnerabilidades puedes detectarse de forma tardía y abordarse después de la implementación del software	FALSO	Realizar análisis de código estático permite detectar errores y vulnerabilidades en el código antes de que el software sea implementado. Esto proporciona la oportunidad de abordar estos problemas antes de que el software entre en producción, lo que ayuda a prevenir problemas más graves en etapas posteriores del desarrollo y reduce los costos asociados con la corrección de errores tardíos. Por lo tanto, el enunciado original es incorrecto.
Una carpeta con un catálogo de imágenes es un ejemplo de datos	No Estructurados	Una carpeta con imágenes se consideraría principalmente como un ejemplo de datos no estructurados.
Cuáles son los requerimientos que abordan la garantía de fiabilidad y protección o prevención contra modificaciones no autorizadas	Requerimiento de integridad	Este requerimiento se enfoca en asegurar que los datos no han sido alterados de manera no autorizada y que permanecen precisos y completos. Garantiza que los datos mantengan su integridad a lo largo del tiempo y no sean modificados por partes no autorizadas, lo que contribuye a prevenir modificaciones no autorizadas y a mantener la confianza en la información almacenada.
Cuál es el instrumento a través del cual se identifican los activos digitales que requieren protección	Políticas de seguridad	Las políticas de seguridad son documentos que establecen las directrices, procedimientos y responsabilidades relacionadas con la seguridad de la información dentro de una organización. Estas políticas suelen incluir criterios para la clasificación de activos digitales, identificando aquellos que son críticos o sensibles y requieren protección especial.
Si un sistema no es capaz de detectar, escalar o alertar sobre ataques activos en tiempo real o casi en tiempo real, a que categoría de amenazas es vulnerable	Security logging and monitoring failure	Esta categoría se refiere a la incapacidad del sistema para detectar y responder adecuadamente a eventos de seguridad, incluidos los ataques activos en tiempo real. La falta de capacidades de detección y respuesta en tiempo real aumenta el riesgo de que los ataques no sean identificados y abordados oportunamente, lo que puede permitir que los adversarios comprometan la seguridad del sistema.

Cómo se conoce la información de identificación que presenta la persona o proceso	Credenciales	Las credenciales son datos que se utilizan para verificar la identidad de un usuario o proceso y otorgar acceso a sistemas, aplicaciones o recursos. Esto puede incluir nombres de usuario, contraseñas, certificados digitales, tokens de seguridad u otros tipos de información que se utilizan para autenticar la identidad de un usuario o proceso. Las credenciales son fundamentales para garantizar la seguridad de los sistemas al limitar el acceso solo a usuarios autorizados.
Qué tipo de arquitectura se basa en servicios en los que cada uno ejecuta en su proceso y se comunica con mecanismos ligeros a menudo una API de recursos HTTP	Microservicios	En esta arquitectura, las aplicaciones se dividen en componentes pequeños e independientes, cada uno conocido como un microservicio, que se pueden desarrollar, desplegar y escalar de manera independiente. Cada microservicio se comunica con otros a través de protocolos ligeros, como HTTP, lo que permite una mayor flexibilidad y modularidad en el diseño y la implementación de aplicaciones.
Que vulnerabilidad es considerada una de las seguridades del software más frecuente y ocurren cuando los datos suministrados por el usuario no se valida antes	Inyección	Este tipo de vulnerabilidad se refiere a la inserción de código malicioso en datos de entrada no validados, que luego es ejecutado por el sistema. Ejemplos comunes incluyen la inyección de SQL (SQL injection) y la inyección de comandos (Command injection). Estas vulnerabilidades pueden permitir a los atacantes ejecutar código no autorizado en el sistema, acceder o manipular datos sensibles, y causar daños significativos.
Todas las excepciones deben ser manejadas explícitamente	VERDADERO	Aunque es una buena práctica manejar explícitamente las excepciones en la mayoría de los casos para garantizar un comportamiento predecible y controlado del programa, hay situaciones en las que no es necesario o incluso no deseable manejar todas las excepciones de manera explícita. Por ejemplo, en algunos programas simples o scripts pequeños, puede ser aceptable dejar que las excepciones no manejadas terminen la ejecución del programa, ya que proporcionan información sobre errores no previstos que necesitan ser corregidos. Además, hay casos donde manejar todas las excepciones explícitamente podría complicar innecesariamente el código, especialmente en situaciones donde es poco probable que ocurran excepciones. En resumen, mientras que manejar explícitamente las excepciones es una buena práctica en la mayoría de los casos, no es necesario hacerlo en todas las situaciones. Por lo tanto, la afirmación es falsa.
Que técnica se utiliza para proteger un software de un ataque de ingeniería inversa	Ofuscación	La ofuscación implica modificar el código de tal manera que sea difícil de entender o de interpretar para los atacantes que intentan realizar ingeniería inversa en el software. Esta técnica puede dificultar el análisis del software y disuadir a los piratas informáticos de intentar descifrarlo o modificarlo para propósitos maliciosos.
Cuáles de los siguientes es un documento de conciencia estándar para desarrolladores y profesionales de seguridad y aplicaciones web dicho documento representa un amplio concepto sobre los riesgos de seguridad más críticos para la aplicaciones web	OWASP Top 10	Es un proyecto de la Open Web Application Security Project (OWASP) que identifica y describe las diez vulnerabilidades de seguridad más críticas en aplicaciones web

*

La lluvia de ideas puede ser aceptada para detectar los requerimientos de seguridad preliminares	VERDADERO	Durante una sesión de lluvia de ideas, los participantes pueden identificar y compartir una amplia gama de posibles riesgos de seguridad, lo que puede ayudar a establecer una base inicial para el diseño y desarrollo de sistemas seguros.	*
El diseño de los mecanismos de protección debe estar abierto al escrutinio de los miembros de la comunidad, a qué principio de seguridad hace referencia el enunciado anterior	Diseño abierto	Implica que los sistemas de seguridad deben ser diseñados de manera que su funcionamiento interno y sus mecanismos de protección estén abiertos y disponibles para ser revisados por la comunidad en general, lo que permite una mayor transparencia y facilita la identificación y corrección de posibles vulnerabilidades. Esto ayuda a mejorar la confianza en la seguridad de los sistemas y promueve la colaboración en la mejora continua de la seguridad.	*
El diseño para la auditoría es extremadamente importante en caso de incumplimiento	VERDADERO	La capacidad de registrar y auditar actividades en un sistema puede ser crucial para comprender lo que sucedió en caso de un incidente de seguridad o un incumplimiento. Los registros adecuados pueden proporcionar información vital para la investigación forense, ayudando a identificar la causa raíz del problema, las actividades realizadas por los atacantes y las medidas necesarias para mitigar el riesgo en el futuro.	
¿En qué estrategia de manejo de riesgos se elige implementar controles de seguridad para reducir el riesgo?	Mitigar el Riesgo	En la mitigación del riesgo, la organización toma medidas activas para reducir la probabilidad de que ocurra un riesgo o para disminuir su impacto en caso de que ocurra. Esto se logra implementando controles de seguridad adecuados, como medidas preventivas, detectivas o correctivas, con el objetivo de reducir la exposición al riesgo identificado. La mitigación del riesgo es una parte esencial de la gestión de riesgos y ayuda a proteger los activos de una organización de posibles amenazas y vulnerabilidades.	****
Completar la oración La. De un software o aplicación es la medida de su exposición hacer explorada por un agente de amenaza.	Superficie de ataque	La "Superficie de ataque" de un software o aplicación es la medida de su exposición a ser explorada por un agente de amenaza.	****
Los mensajes de error son una de las primeras fuentes que un atacante buscará para determinar la información sobre el software.	VERDADERO	Los mensajes de error detallados podrían revelar información sensible sobre la estructura interna del sistema, la tecnología utilizada o incluso datos de usuario. Por lo tanto, los atacantes a menudo buscan explotar esta información para lanzar ataques dirigidos con mayor precisión. Es importante para los desarrolladores y administradores de sistemas limitar la cantidad de información sensible revelada en los mensajes de error y proporcionar solo la información necesaria para diagnosticar problemas sin comprometer la seguridad del sistema.	
¿Qué técnicas de sanitización hace uso de propiedades que hacen que la entrada proporcionada por el usuario se trate como una forma literal?	Literalización	Los datos de entrada se interpretan exactamente como se proporcionan, sin realizar ningún procesamiento o modificación. Esto puede ser útil en situaciones donde es importante mantener la integridad de los datos de entrada tal como fueron ingresados por el usuario, pero también puede aumentar el riesgo de ataques de inyección si los datos no son validados o filtrados adecuadamente.	****

Cómo se llama el principio de seguridad que indica que Únicamente se debe otorgar los permisos necesarios para que alguien pueda completar la tarea asignada.	Menor privilegio	Este principio sugiere que los usuarios, procesos y sistemas solo deben tener acceso a los recursos y datos necesarios para realizar sus funciones específicas, y no se les debe otorgar acceso a recursos adicionales que no son esenciales para su tarea asignada. Esto ayuda a reducir la superficie de ataque y a limitar el impacto en caso de que ocurra una violación de seguridad.
Cuáles de los siguientes requerimientos responde a la pregunta de qué se permite o no hacer.	Requerimiento de autorización	Este tipo de requerimiento establece las reglas y políticas que determinan qué acciones están permitidas para un usuario, un proceso o un sistema una vez que se ha establecido la autenticación. La autorización determina los permisos y los niveles de acceso que tienen los usuarios sobre recursos específicos, como archivos, bases de datos o funcionalidades de una aplicación. Es decir, define quién tiene acceso a qué recursos y qué operaciones pueden realizar.
El software o la información debe ser accesible solo a las identidades autorizadas al momento que se requiera a que característica a hace referencia.	Disponibilidad	La integridad asegura que el software o la información no sean modificados de manera no autorizada y que solo estén disponibles para las identidades autorizadas cuando se necesiten. Por lo tanto, la integridad garantiza que los datos no sean alterados, corrompidos o manipulados de forma no autorizada, manteniendo su precisión y fiabilidad.
A qué rol se refiere alguien que se esencialmente usa sus conocimientos técnicos y habilidades para resolver los problemas que tiene el negocio usando lenguaje de programación.	Programador	Los programadores son responsables de traducir los requisitos y las especificaciones del negocio en código ejecutable, desarrollando aplicaciones, sistemas y soluciones informáticas para satisfacer las necesidades de la organización.
Se recomienda como una mejor práctica, redirigir los errores y las excepciones a una ubicación de manejo de errores personalizada y predeterminada y según el contexto de inicio de sesión del usuario ya sea remoto o local se puede mostrar los detalles de los mensajes apropiados.	VERDADERO	Es una buena práctica redirigir los errores y las excepciones a una ubicación de manejo de errores personalizada y predeterminada. Esto permite un manejo más eficiente de los errores y una mejor experiencia del usuario, ya que se pueden proporcionar mensajes de error claros y apropiados según el contexto de inicio de sesión del usuario, ya sea remoto o local. Proporcionar mensajes de error específicos y útiles es importante para facilitar la resolución de problemas y para garantizar la seguridad y la integridad del sistema.
Manejo de errores explícitamente usando redireccionamientos y mensajes de error para que el incumplimiento de cualquier configuración incorrecta no resulte la divulgación de más información de la necesaria. ¿Lo anterior es una técnica de mitigación para que tipo de vulnerabilidad	XSS	Es una vulnerabilidad que permite a un atacante insertar scripts maliciosos en páginas web vistas por otros usuarios. Al manejar los errores explícitamente y redireccionar adecuadamente, junto con el uso de mensajes de error que no divulguen más información de la necesaria, se reduce la posibilidad de que un atacante pueda explotar la vulnerabilidad de XSS para obtener información sensible o realizar ataques más avanzados.

Almacenar la clave criptográfica junto con los datos que se están respaldando es un ejemplo de vulnerabilidad criptográfica.	VERDADERO	Esto comprometería la seguridad de los datos cifrados, ya que cualquiera que obtenga acceso a la clave podría descifrar fácilmente los datos protegidos. En la criptografía, es esencial mantener las claves seguras y separadas de los datos cifrados para garantizar su confidencialidad e integridad.	*
Establezca explícitamente un Time-Outs y diseñe el software para que automáticamente realice el log-off de sesiones inactivas, ¿Lo anterior es una técnica de mitigación para cual categoría de vulnerabilidades?	Broken Access Control	La implementación de un timeout y el cierre automático de sesiones inactivas ayudan a prevenir ataques relacionados con el control de acceso, como la usurpación de sesiones (session hijacking) y el acceso no autorizado a recursos protegidos por el sistema de control de acceso. Esto garantiza que las sesiones no permanezcan abiertas indefinidamente, lo que podría ser aprovechado por un atacante para obtener acceso no autorizado a los recursos del sistema.	*
Consiste en agregar recursos adicionales al nodo existente. A qué tipo de escalabilidad hace referencia el enunciado anterior.	Escalabilidad vertical	Implica agregar recursos adicionales al nodo existente, como aumentar la capacidad de procesamiento, memoria o almacenamiento en un servidor único.	
¿Qué requerimientos verifican y aseguran la legitimidad y validez de la identidad de alguna entidad?	Requerimientos de Autenticación	Es el proceso de verificar la identidad de una entidad, como un usuario, un dispositivo o un sistema, para asegurar que realmente sea quien afirma ser. Por lo tanto, los requerimientos de autenticación son los que garantizan la legitimidad y validez de la identidad de una entidad.	*
Cuál de los siguientes principios de seguridad nos indica que no se deben permitir violaciones de seguridad en caso de una falla.	Fallo Seguro	Se refiere a diseñar sistemas de manera que, en caso de falla, no comprometan la seguridad del sistema en su conjunto. Esto implica que, ante cualquier fallo o error, el sistema debería mantenerse en un estado seguro o, en algunos casos, cerrarse de forma segura para evitar mayores daños o intrusiones. Este principio es fundamental para garantizar la confiabilidad y seguridad de los sistemas en situaciones de emergencia o fallo.	
Todos los datos necesitan el mismo nivel de protección por ejemplo los datos públicos requieren una protección mínima o nula contra la divulgación.	FALSO	Diferentes tipos de datos pueden requerir niveles de protección diferentes, dependiendo de su sensibilidad, su importancia para la organización y los requisitos legales o regulatorios. Los datos públicos, que son aquellos que no contienen información confidencial o sensible, pueden requerir una protección mínima o nula contra la divulgación. Sin embargo, otros tipos de datos, como la información personal, financiera o de salud, pueden requerir niveles más altos de protección para garantizar su confidencialidad, integridad y disponibilidad. Por lo tanto, es importante evaluar y clasificar los datos en función de su sensibilidad y aplicar medidas de protección adecuadas en consecuencia.	
Qué categoría de modelo STRIDE habla acerca de la interrupción del servicio que afecta la disponibilidad.	Denegación de Servicio	Se refiere a la interrupción intencional o accidental del servicio que afecta la disponibilidad de un sistema. Este tipo de ataque busca sobrecargar recursos, como ancho de banda, capacidad de almacenamiento o capacidad de procesamiento, con el objetivo de hacer que un sistema o servicio sea inaccesible para los usuarios legítimos.	*

La _____ generalmente sigue un esquema de copia de seguridad maestro-esclavo o primario-secundario en el que hay un nodo maestro o primario y las actualizaciones se prologan a los esclavos o nodos secundarios de forma activa o pasiva.	Replicación	Es el proceso en el que los datos de un nodo maestro o primario se propagan o se copian a nodos secundarios o esclavos, es comúnmente utilizada en esquemas de copia de seguridad maestro-esclavo o primario-secundario para garantizar la disponibilidad y la redundancia de los datos.	*
El control de versiones puede reducir la incidencia de una condición conocida como _____, donde los errores previamente corregidos reaparecen.	Errores Regenerativos	El control de versiones, al permitir el seguimiento de cambios en el código fuente y la capacidad de volver a versiones anteriores, ayuda a reducir la incidencia de estos errores regenerativos al permitir a los desarrolladores identificar dónde y cómo se introdujeron los errores nuevamente.	***
Que técnica se utiliza para detectar problemas semánticos como la lógica empresarial y las fallas de diseño?	Revisiones de código	Esta técnica puede ser especialmente útil para detectar ciertos tipos de problemas semánticos, como inconsistencias en la lógica del programa o en el flujo de control, aunque es menos efectiva para detectar problemas relacionados con la lógica empresarial específica, que pueden requerir un entendimiento más profundo del dominio del problema.	*
El atacante proporciona datos que se aceptan tal cual son interpretados como un _____ como un comando que permite ejecutar comandos como un vector de inyección. ¿De que tipo de vulnerabilidad estamos hablando?	Injection	Es una vulnerabilidad en la que un atacante proporciona datos maliciosos que se aceptan y se interpretan como parte de un comando o consulta que permite la ejecución de acciones no deseadas en el sistema. Esto puede ocurrir en varios contextos, como inyección de SQL, inyección de comandos (como en el caso de shell injection) o inyección de código HTML. La opción "c. Inyección" es la respuesta correcta en este caso.	*
Una llave criptográfica debe mantenerse en secreto y se conoce como la _____ mientras que la otra se divulga a cualquier persona	Llave Privada	Es la que debe mantenerse en secreto y es conocida únicamente por su propietario. Se utiliza para descryptar datos cifrados con la llave pública correspondiente.	***
"Usar componentes descargados de fuentes oficiales a través de comunicación segura" ¿Es una técnica de mitigación segura, para qué tipo de vulnerabilidad es?	Vulnerable and Outdate Components	Esta técnica ayuda a mitigar el riesgo asociado con el uso de componentes de software que pueden tener vulnerabilidades conocidas o estar desactualizados, lo que podría ser explotado por atacantes. Al descargar componentes de fuentes oficiales y utilizar comunicación segura, se reduce la probabilidad de instalar componentes comprometidos o modificados por terceros malintencionados.	***
La ejecución de código libre requiere que se hagan diferentes actualizaciones. Mantener elementos estáticos es otorgar vulnerabilidades ya conocidas a los atacantes, de esta forma es necesario informar al equipo de desarrollo que actualice cualquier elemento que involucre código open source, bajo que categorías de amenazas se encuentra este riesgo de seguridad?	Vulnerable and Outdated Components	Este riesgo se refiere a la utilización de componentes de software que contienen vulnerabilidades conocidas o que están desactualizados, lo que puede ser explotado por atacantes para comprometer la seguridad del sistema. En este caso, se trata específicamente de componentes de código abierto que necesitan actualizaciones periódicas para corregir vulnerabilidades y mantener la seguridad del sistema.	
Cuando programamos en lenguaje ensambladores un ejemplo de uso de lenguaje de que nivel?	Bajo Nivel	El lenguaje ensamblador es un lenguaje de programación de bajo nivel que está estrechamente relacionado con el lenguaje máquina y proporciona una representación simbólica de las instrucciones y estructuras de datos que una arquitectura de computadora específica puede ejecutar. Aunque es más legible que el lenguaje máquina, sigue siendo bastante cercano a las instrucciones reales del procesador y a la arquitectura subyacente del hardware.	

Cuando no se permiten dos operaciones simultáneas en el mismo objeto (digamos un registro en la base de datos), porque una de las operaciones bloquea ese registro para para que no permita ningún cambio, ¿De qué concepto estamos hablando?	Bloqueo de Recursos	Es una técnica utilizada para controlar el acceso concurrente a recursos compartidos, como registros en una base de datos. Cuando se aplica un bloqueo a un recurso, impide que otros procesos o usuarios realicen operaciones simultáneas en el mismo recurso. En el caso descrito, cuando una operación bloquea un registro en la base de datos para evitar cambios concurrentes, se está aplicando un bloqueo de recursos en ese registro. Esto garantiza la consistencia y la integridad de los datos durante operaciones concurrentes.	*
Que archivo acredita que la persona o entidad que lo posee es realmente quien dice ser?	Certificado Digital	Se utiliza para verificar la identidad del titular y garantizar la integridad y autenticidad de los datos que se envían y reciben a través de Internet. Proporciona una forma segura de establecer la identidad y la confianza entre las partes en una transacción en línea.	
Las políticas de seguridad deben ser evaluadas periódicamente para que se mantengan correctas y relevantes y actualizadas conforme a la amenazas actuales	VERDADERO	Las amenazas y los entornos de seguridad cambian con el tiempo, por lo que es importante revisar y actualizar regularmente las políticas de seguridad para abordar nuevas amenazas, tecnologías emergentes y cambios en el entorno empresarial. Esto ayuda a garantizar que las políticas de seguridad sigan siendo efectivas y adecuadas para proteger los activos de la organización.	
Complete la siguiente oración: La _____ de código utiliza una variedad de técnicas para hacer que el código fuente sea confuso o ilegible	Ofuscación	Es una técnica que se utiliza para hacer que el código fuente sea más confuso o ilegible, lo que dificulta su comprensión por parte de terceros. Esta técnica se utiliza a menudo para proteger la propiedad intelectual, dificultar la ingeniería inversa y dificultar la explotación de vulnerabilidades en el software.	
Que categoría del modelo DREAD clasifica lo fácil que es para investigadores externos y atacantes para descubrir la amenaza	Descubrimiento	Se refiere a la facilidad con la que los investigadores externos y los atacantes pueden descubrir la amenaza. Esto puede incluir la accesibilidad pública de la vulnerabilidad, la documentación disponible sobre ella, si se ha hecho pública, etc. Cuanto más fácil sea para los atacantes descubrir la amenaza, mayor será el valor asignado a esta categoría en el modelo DREAD.	
¿A que característica de software nos estamos refiriendo en el siguiente ejemplo? Al hacer una transferencia bancaria se espera que el monto transferido sea exactamente el monto que se autorizó ¿A que característica de software nos estamos refiriendo?	Integridad	Se refiere a la precisión y exactitud de los datos y la consistencia de las operaciones realizadas. En el caso de una transferencia bancaria, se espera que el monto transferido sea exactamente el mismo que el autorizado, lo que indica la integridad de la operación.	**
Como se denomina el proceso de conversión de datos que tiene más de una representación posible para ajustarse a una forma estándar?	Canonicalización	Es el proceso de convertir datos en una forma estándar o canónica, lo que implica asegurar que los datos estén representados de manera consistente y uniforme, independientemente de su forma original. Esto ayuda a garantizar la integridad y la seguridad de los datos, especialmente en contextos donde la entrada de datos puede ser manipulada por usuarios malintencionados para explotar vulnerabilidades.	***

La validación de entrada es el proceso de verificación que garantiza que los datos que se proporcionan para el procesamiento sean del tipo y formato correctos	VERDADERO	Es el proceso de verificar que los datos proporcionados para el procesamiento sean del tipo y formato correctos. Esto ayuda a garantizar la integridad y consistencia de los datos antes de que sean procesados por el sistema, lo que puede prevenir errores y vulnerabilidades.	
¿Qué tipo de datos es la información almacenada en bases de datos no relacionales?	Semi Estructurados	Las bases de datos no relacionales, también conocidas como bases de datos NoSQL, son conocidas por su capacidad para almacenar datos no estructurados o semiestructurados de manera eficiente.	****
El diseño de los mecanismos de producción debe estar abierto al escrutinio de los miembros de la comunidad. A qué principio de seguridad hace referencia el enunciado anterior?	Diseño Abierto	Implica que los sistemas de seguridad deben estar abiertos al escrutinio público, lo que significa que los detalles de implementación y funcionamiento deben ser transparentes y accesibles para la comunidad en general. Esto facilita la identificación de posibles vulnerabilidades y debilidades en el diseño, ya que permite que múltiples partes interesadas revisen y evalúen el sistema de seguridad.	****
El hecho de que el código se compile sin ningún error, que pueda analizarse mediante el análisis de código estático, significa que se ejecutara sin ningún error?	FALSO	El hecho de que el código se compile sin ningún error y que pueda ser analizado mediante el análisis de código estático no garantiza que se ejecutará sin errores. La compilación y el análisis de código estático pueden ayudar a identificar problemas de sintaxis y posibles vulnerabilidades, pero no pueden detectar todos los errores que pueden surgir durante la ejecución del programa.	*
Cuál de las siguientes es una técnica-anti manipulación para asegurar la integridad y la protección contra alteraciones no autorizadas y maliciosas del código del software y/o o los datos?	Firmado de Código	Es una técnica que implica agregar una firma digital al código del software para verificar su autenticidad e integridad. Cuando el software está firmado digitalmente, cualquier alteración no autorizada del código provocaría que la firma digital no coincidiera, lo que alertaría sobre la manipulación del código. Esto ayuda a garantizar que el código no haya sido modificado de manera maliciosa o no autorizada desde su publicación inicial.	*
Qué tipo de arquitectura permite la creación de sistemas de información altamente escalables que reflejan el negocio de la organización, y su vez brinda una forma bien definida de exposición e innovación de servicios, facilitando la interacción entre diferentes sistemas propios o de terceros?	SOA	Es un enfoque para diseñar sistemas de software en el que los servicios se ofrecen a través de una red, generalmente a través de estándares abiertos. Esto permite que los componentes de software estén bien definidos, sean independientes y reutilizables, lo que facilita la escalabilidad y la interoperabilidad entre sistemas.	*
El software o la información deben ser accesibles solo a las entidades autorizadas al momento que se requiera, A que característica hace referencia el enunciado anterior?	Disponibilidad	Se refiere a que el software o la información estén disponibles y accesibles para las entidades autorizadas en el momento que se requiera. Esto implica que los sistemas y los datos estén disponibles cuando sea necesario para su uso legítimo, pero no necesariamente para todas las entidades. La disponibilidad se relaciona con la capacidad de un sistema para funcionar correctamente y proporcionar acceso a los recursos cuando sea necesario.	

Este principio se enfoca en asegurarse que la superficie de ataque no es incrementada y no se introducen nuevas vulnerabilidades, mediante la reutilización de componentes de software, código o funcionalidad, de que principio estamos hablando?	Aprovechamiento de Componentes ya Existentes	Este principio se centra en utilizar componentes de software, código o funcionalidad ya existentes en lugar de desarrollar nuevos, con el fin de reducir la superficie de ataque y minimizar la introducción de nuevas vulnerabilidades. Al reutilizar componentes probados y bien establecidos, se puede reducir el riesgo de errores y vulnerabilidades en el sistema.	*
Cuando trabajamos con contenedores se recomienda que las imágenes del contenedor estén firmadas y provengan de fuentes confiables.	VERDADERO	Cuando trabajamos con contenedores, es una práctica recomendada que las imágenes del contenedor estén firmadas digitalmente y provengan de fuentes confiables. La firma digital de las imágenes del contenedor ayuda a garantizar su autenticidad e integridad, mientras que obtener las imágenes de fuentes confiables reduce el riesgo de utilizar imágenes comprometidas o maliciosas que puedan contener vulnerabilidades o código malicioso. Esto es especialmente importante en entornos de producción donde la seguridad y la integridad del software son críticas.	****
Una de las consideraciones de diseño más importantes es diseñar el software para que pueda proporcionar evidencia histórica de las acciones del usuario y del sistema. ¿A que concepto hace referencia el enunciado anterior?	Auditoría	Se refiere a la capacidad del sistema para registrar y almacenar evidencia histórica de las acciones realizadas por los usuarios y el sistema. Esto es crucial para garantizar la transparencia, la responsabilidad y la capacidad de investigar eventos pasados en un sistema. Permite realizar un seguimiento de quién ha accedido al sistema, qué acciones han realizado y cuándo se llevaron a cabo, lo que puede ser fundamental para cumplir con los requisitos de seguridad y regulaciones, así como para investigar incidentes de seguridad.	****
Como qué tipo de lenguaje se puede considerar cuando trabajamos en C# de .Net	Compilado	Significa que el código fuente escrito en C# se compila en un lenguaje intermedio llamado CIL (Common Intermediate Language) o IL (Intermediate Language), que luego se ejecuta en tiempo de ejecución por el Common Language Runtime (CLR) de .NET.	*
Qué tipo de técnica implementa filtros que se usan para validar la forma canónica o estándar de una entrada?	Expresiones Regulares	Técnica que se utiliza para validar y ajustar las entradas de datos a una forma canónica o estándar. Esto implica la aplicación de filtros y transformaciones a los datos de entrada para asegurarse de que cumplan con ciertos criterios o patrones específicos. Las expresiones regulares, mencionadas en la opción c, son a menudo utilizadas como parte de la regularización para definir patrones de texto que deben ser cumplidos por los datos de entrada.	
Los beneficios de realizar análisis de código estático son que los errores y las vulnerabilidades pueden detectarse de forma tardía y abordarse después de la implementación del software.	FALSO	Incluyen la capacidad de detectar errores y vulnerabilidades en una etapa temprana del ciclo de desarrollo de software, antes de que el código se implemente o se ejecute en un entorno de producción. Al identificar y abordar estos problemas temprano, se reduce significativamente el costo y el tiempo asociados con la corrección de errores más tarde en el proceso de desarrollo.	**

Cuáles son los requerimientos que abordan la garantía de fiabilidad y protección o prevención contra modificaciones no autorizadas	Requerimiento de Integridad	Se enfoca en asegurar que los datos o el sistema se mantengan íntegros y no sean modificados de manera no autorizada. Este tipo de requerimiento se centra en garantizar que la información almacenada o transmitida permanezca exactamente como se espera y no sea alterada por personas no autorizadas o procesos no autorizados.	Enunciado
Cuál es el instrumento a través del cual se identifican los activos digitales que requieren protección	Políticas de Seguridad	Son documentos que establecen las directrices, procedimientos y estándares para proteger los activos digitales y la información de una organización. Estas políticas definen qué activos son críticos y necesitan protección, así como también establecen los procedimientos para protegerlos de amenazas y vulnerabilidades. Por lo tanto, las políticas de seguridad son el instrumento principal para identificar los activos digitales que requieren protección en una organización.	
Cómo se conoce la información de identificación que presenta la persona o proceso	Credenciales	Son la información que se presenta para verificar la identidad de una persona o proceso. Esto puede incluir nombres de usuario, contraseñas, certificados digitales u otros tipos de información de identificación. Las credenciales se utilizan en los sistemas de autenticación para verificar que una entidad sea quien dice ser antes de permitir el acceso a recursos o información protegida.	
Qué tipo de arquitectura se basa en servicios en los que cada uno ejecuta en su proceso y se comunica con mecanismos ligeros a menudo una API de recursos HTTP	Microservicios	Estos servicios se comunican entre sí a través de mecanismos ligeros, como una API de recursos HTTP, lo que permite una comunicación flexible y escalable entre ellos. Esta arquitectura se enfoca en la modularidad y la independencia de los servicios, lo que facilita el desarrollo, la implementación y el mantenimiento de sistemas complejos.	
Todas las expresiones deben ser manejadas explícitamente	FALSO	Algunas expresiones son manejadas implícitamente por el compilador o el entorno de ejecución. Por ejemplo, en algunos casos, la conversión automática de tipos puede ocurrir sin que el programador lo especifique explícitamente. Sin embargo, es una buena práctica ser explícito en la manipulación de expresiones siempre que sea posible, ya que esto puede mejorar la legibilidad y la comprensión del código, así como ayudar a evitar errores sutiles.	
Que técnica se utiliza para proteger un software de un ataque de ingeniería inversa	Ofuscación	Es una técnica que se utiliza para hacer que el código fuente de un programa sea más difícil de entender o interpretar. Esto se logra mediante la aplicación de transformaciones al código que no afectan su funcionalidad pero dificultan la comprensión del mismo para un humano. La ofuscación puede hacer que sea más complicado para los atacantes analizar el código y extraer información valiosa, lo que ayuda a protegerlo contra la ingeniería inversa.	
El diseño para la auditoría es extremadamente importante en caso de incumplimiento principalmente por fines forenses.	VERDADERO	La capacidad de auditar y rastrear eventos en un sistema es esencial para investigar incidentes de seguridad, determinar la causa raíz de un incumplimiento y recopilar evidencia forense para acciones legales o medidas correctivas. Un diseño adecuado para la auditoría asegura que los registros y eventos relevantes se registren de manera adecuada y se puedan recuperar de manera efectiva cuando sea necesario. Esto puede ser crucial para manejar incidentes de seguridad y demostrar cumplimiento regulatorio.	

Se recomienda como una mejor práctica, redirigir los errores y las excepciones a una ubicación de manejo de errores personalizada y predeterminada y según el contexto de inicio de sesión del usuario ya sea remoto o local se puede mostrar los detalles de los mensajes apropiados.	VERDADERO	Es una práctica recomendada redirigir los errores y las excepciones a una ubicación de manejo de errores personalizada y predeterminada. Esto ayuda a centralizar el manejo de errores y facilita la identificación y resolución de problemas. Además, mostrar mensajes de error apropiados según el contexto de inicio de sesión del usuario (ya sea remoto o local) es importante para proporcionar una experiencia de usuario adecuada y para mantener la seguridad del sistema.	
Un ejemplo de _____ sería instalar copias adicionales del mismo software o agregar un servidor proxy de caché a la implementación existente de aplicaciones.	Escalabilidad Horizontal	Implica agregar más instancias o recursos en paralelo para distribuir la carga y aumentar la capacidad del sistema. En el ejemplo dado, al instalar copias adicionales del mismo software o agregar un servidor proxy de caché, se está distribuyendo la carga de trabajo entre múltiples instancias del software o servicios, lo que permite manejar más tráfico o demanda de manera eficiente. Esto es característico de la escalabilidad horizontal, ya que se está ampliando el sistema de manera horizontal mediante la adición de más recursos, en lugar de aumentar la capacidad de recursos individuales (como en la escalabilidad vertical). Por lo tanto, el ejemplo proporcionado se alinea con el concepto de escalabilidad horizontal.	****
Casi cualquier fuente que acepte datos es un vector de inyección potencial si los datos no se validan antes de su procesamiento	VERDADERO	Los ataques de inyección, como la inyección de SQL, la inyección de comandos, entre otros, son comunes cuando los datos entrantes no se validan correctamente antes de su uso en aplicaciones o sistemas.	
El dueño del negocio también se conoce como el dueño de los datos	FALSO	Aunque el dueño del negocio puede tener cierta influencia sobre los datos, no siempre es la misma persona que el "dueño de los datos" en el sentido de gestión y responsabilidad directa sobre ellos.	***
No combinar el rol de la persona que recibe pagos y la persona que los aprueba ¿A qué principio de seguridad corresponde el enunciado anterior?	Separación de Responsabilidades	Este principio establece que ciertas funciones críticas dentro de una organización deben ser asignadas a diferentes personas para evitar conflictos de interés y reducir el riesgo de fraudes o errores.	****
Si un usuario malintencionado logra sobrescribir la dirección de retorno para apuntar a un espacio de direcciones en la memoria, donde se ha inyectado un código de explotación (también conocido como capa útil), luego de completar una función, la dirección de retorno sobrescrita (contaminada) será cargada en el registro EIP, y la ejecución del programa se desbordará ejecutando potencialmente la carga maliciosa.	Buffer Overflow	En un desbordamiento de búfer, un atacante intenta escribir más datos en un búfer de los que puede contener, lo que puede llevar a sobrescribir otras áreas de la memoria, como la dirección de retorno de una función. Cuando esto sucede, la dirección de retorno sobrescrita apunta al código malicioso inyectado por el atacante en lugar de a la dirección de retorno esperada. Esto puede permitir al atacante ejecutar código arbitrario en el sistema afectado, comprometiendo su seguridad.	****
¿Cuál de los siguientes elementos permite verificar la integridad de la información?	Funciones de Hash	Son ampliamente utilizadas para verificar la integridad de la información. Estas funciones toman una entrada (o mensaje) y generan una cadena de salida de longitud fija, conocida como hash. La característica fundamental de estas funciones es que un cambio incluso mínimo en la entrada resulta en un hash completamente diferente.	*

¿Qué tipo de análisis implica la inspección de código o programas de software sin ejecutarlos?	Análisis de Código Estático	Implica revisar el código fuente o binario de un programa sin ejecutarlo. Durante este proceso, se examinan aspectos como la estructura del código, la calidad del mismo, la detección de vulnerabilidades y la conformidad con estándares de codificación. Esto se realiza mediante herramientas específicas diseñadas para analizar el código en busca de posibles problemas sin necesidad de ejecutar el programa.	*****
¿Cómo se llama el método para engañar a los usuarios para que envíen su información personal a través de medios electrónicos como correos electrónicos y sitios web falsos?	Phishing	Es una técnica utilizada por ciberdelincuentes para obtener información confidencial de los usuarios, como contraseñas, números de tarjetas de crédito, información financiera, entre otros, haciéndose pasar por entidades legítimas a través de correos electrónicos, mensajes de texto o sitios web falsos.	
¿Qué técnica se utiliza para detectar bombas lógicas?	Análisis de Código Estático	Las bombas lógicas son porciones de código malicioso que están diseñadas para activarse en ciertas condiciones o eventos específicos, como una fecha o una acción del usuario. Al realizar un análisis de código estático, se pueden identificar posibles bombas lógicas mediante la revisión del código en busca de patrones sospechosos o instrucciones que puedan activar acciones no deseadas.	*****
Valide la entrada proporcionada por el usuario con una lista blanca, así como todos los encabezados, cookies, valores de cadena de consulta de URL, campos de formulario y campos ocultos ¿Lo anterior es una técnica de mitigación para qué tipo de vulnerabilidad? ☐	Broken Access Control	Al utilizar una lista blanca y verificar exhaustivamente los datos proporcionados por el usuario y otros elementos, se ayuda a garantizar que solo se acepten datos válidos y seguros, reduciendo así el riesgo de que se realicen ataques de inyección de código.	****
Sólo porque las credenciales de una entidad fueron validadas, no significa que tenga acceso a todos los recursos que solicite. ¿Cómo se conoce al proceso de validar los derechos y privilegios?	Autorización	Incluyen problemas relacionados con la identificación y autenticación de usuarios, lo que podría permitir a un atacante obtener control sobre una sesión válida, interponerse en el medio y hacerse pasar por usuarios legítimos. Esto podría incluir la suplantación de identidad, el secuestro de sesión y otros ataques que exploten debilidades en los mecanismos de identificación y autenticación.	*
¿Qué tipo de requerimientos sirven para garantizar que no haya interrupciones en las operaciones de negocio?	Disponibilidad	Se refiere a la capacidad de los sistemas de estar en funcionamiento y accesibles cuando se los necesita. Garantizar la disponibilidad significa asegurarse de que los servicios y recursos estén disponibles para su uso en todo momento, minimizando las interrupciones en las operaciones de negocio. Esto puede lograrse mediante redundancia, tolerancia a fallos, planes de recuperación ante desastres, entre otras medidas.	
¿A qué principio de seguridad se refiere que los errores y excepciones se manejen explícitamente y los mensajes de error sean de naturaleza no detallada?	Fallo Seguro	Se centra en asegurar que los sistemas fallen de manera segura, es decir, que si ocurre un fallo o error, el sistema no se vuelva vulnerable o expuesto a ataques. En este contexto, manejar los errores y excepciones de manera explícita y limitar la información revelada en los mensajes de error contribuye a la seguridad general del sistema al evitar que los posibles atacantes obtengan información sensible que puedan utilizar para comprometer la seguridad del sistema.	*****

Complete la siguiente oración: La _____ se logra mediante la implementación de controles de seguridad	Mitigación	Describe el proceso de implementar controles de seguridad para reducir o mitigar los riesgos asociados con amenazas y vulnerabilidades en un sistema de información.	*
¿Cuál de los siguientes se refiere a recursos que un atacante puede aprovechar para construir un ataque contra el software?	Superficie de Ataque	Se refiere al conjunto de recursos expuestos y accesibles que pueden ser aprovechados por un atacante para realizar un ataque contra el software. Esto puede incluir servicios, interfaces, puertos, protocolos y cualquier otro elemento que pueda ser utilizado como punto de entrada para un ataque.	*
¿A qué categoría de amenazas es vulnerable su aplicación si no es capaz de registrar la advertencias y los errores que genera la aplicación?	Security Logging and Monitoring Failures	Si una aplicación no es capaz de registrar advertencias y errores, se está dejando vulnerable a amenazas como la falta de visibilidad sobre actividades maliciosas o anómalas que podrían estar ocurriendo en el sistema.	***
Complete la siguiente oración: Los _____ son debido a la codificación / implementación que pueden causar brechas en la seguridad.	Vulnerabilidades	Son problemas en el código de un programa que causan un comportamiento no deseado o incorrecto. Estos errores pueden ser el resultado de errores en la codificación o implementación del software.	***
¿Cómo se denomina a la técnica que consiste en deshabilitar todos aquellos servicios que no vayan a prestar una funcionalidad del sistema?	Security Misconfiguración	La seguridad de un sistema puede ser comprometida por configuraciones incorrectas o inseguras. Deshabilitar los servicios innecesarios es una práctica común para reducir la superficie de ataque, minimizando así el riesgo de exposición a amenazas.	*
El administrador de la base de datos con acceso sin restricciones y sin auditar la información confidencial directamente es una fuente de amenaza potencial que no debe ignorarse ¿A qué tipo de agente de amenaza humana corresponde la descripción anterior?	Insider	Es un agente de amenaza humano que tiene acceso legítimo a los sistemas o datos de una organización y puede utilizar ese acceso para llevar a cabo actividades maliciosas o dañinas.	
¿Cuál es el instrumento a través del cual se identifican los activos digitales que requieren protección?	Políticas de Seguridad	Son documentos que establecen las directrices y procedimientos para proteger los activos digitales de una organización. Estas políticas incluyen la identificación de los activos digitales que requieren protección, así como las medidas y controles necesarios para garantizar su seguridad.	***
Si un sistema no es capaz de detectar, escalar o alertar sobre ataques activos en tiempo real o casi en tiempo real, a que categoría de amenazas es vulnerable.	Security Logging and Monitoring Failures	Se refiere a la incapacidad del sistema para registrar y monitorear de manera efectiva los eventos de seguridad, lo que incluye la detección de ataques en tiempo real o casi en tiempo real. Cuando un sistema no puede detectar, escalar o alertar sobre ataques activos de manera oportuna, existe una falla en el proceso de registro y monitoreo de la seguridad, lo que deja al sistema vulnerable a diversas amenazas.	
Cómo se conoce la información de identificación que presenta la persona o proceso	Credenciales	Son los datos utilizados para verificar la identidad de una persona o proceso. Esto puede incluir nombres de usuario, contraseñas, certificados digitales, tokens de seguridad, entre otros. Las credenciales se utilizan para autenticar la identidad de un usuario o proceso antes de permitir el acceso a sistemas, redes, aplicaciones u otros recursos protegidos.	

La _____ es un principio de seguridad que establece que las solicitudes de acceso deben ser medida siempre de modo que no se eluda la autoridad en solicitudes posteriores	Separación de Responsabilidades	Es un principio de seguridad que establece que las funciones y los privilegios en un sistema deben ser distribuidos de manera que una persona o entidad no tenga acceso completo o control total sobre un sistema o proceso.	
¿En una CPU como se llaman los espacios de almacenamiento de memoria interna especializados dentro del propio procesador?	Registros	Son los espacios de almacenamiento de memoria interna en una CPU. La unidad aritmética lógica (ALU) es responsable de realizar operaciones aritméticas y lógicas en los datos almacenados en los registros. Entonces, mientras que la ALU realiza operaciones en los datos almacenados en los registros, estos registros son los espacios de almacenamiento en sí mismos.	*
Qué término significa que alguien no puede negar sus acciones	No Repudio	Es un término utilizado en seguridad de la información que se refiere a la capacidad de garantizar que una parte en una comunicación o transacción no pueda negar su participación o la validez de la acción realizada. Es importante especialmente en transacciones electrónicas y comunicaciones digitales, donde se necesita asegurar que las partes involucradas no puedan negar haber enviado o recibido ciertos datos o haber llevado a cabo ciertas acciones.	
Cuál es una de las principales funciones del custodio de los datos	Realizar el ejercicio de clasificación de información, realizar copias de seguridad y recuperación según lo especificado por el propietario de los datos	Esto incluye clasificar la información, realizar copias de seguridad y recuperación de datos, y garantizar su integridad y disponibilidad de acuerdo con las directrices establecidas.	*
¿Qué algoritmos criptográficos se caracterizan por compartir una llave entre el emisor y el receptor?	Algoritmos Simétricos	Utilizan la misma clave tanto para cifrar como para descifrar los datos. Esto significa que el emisor y el receptor deben compartir la misma clave de antemano para comunicarse de forma segura. Ejemplos comunes de algoritmos simétricos son DES (Data Encryption Standard), AES (Advanced Encryption Standard) y Blowfish.	*
¿Cómo se denomina a la práctica de estafa en la que se instala código malicioso en un sistema o servidor que dirige a los usuarios a sitios web fraudulentos sin el conocimiento o consentimiento del usuario?	Pharming	Los atacantes utilizan técnicas para modificar la configuración del DNS o comprometer servidores DNS legítimos para que apunten a los usuarios a sitios web maliciosos cuando intentan acceder a dominios legítimos.	*
Según el principio de seguridad de "Fallo Seguro", no debemos diseñar el software para ignorar el error y reanudar la siguiente operación.	VERDADERO	Cuando se produce un error en el software, no se debe ignorar ni suponer que el problema se resolverá solo. En cambio, el software debe ser diseñado para manejar los errores de manera segura y adecuada, y no simplemente continuar con la siguiente operación como si no hubiera ocurrido ningún problema. El software debe tomar medidas para mitigar los efectos del error y garantizar que el sistema siga siendo seguro y funcional.	*
La firma digital que se utiliza para firmar un mensaje no puede ser fácilmente imitada por alguien a menos que esta se vea comprometida.	VERDADERO	Se utiliza para garantizar la autenticidad, integridad y no repudio de un mensaje o documento digital. Una firma digital se crea mediante un algoritmo criptográfico utilizando una clave privada y luego se verifica utilizando una clave pública correspondiente. Si la firma digital se genera correctamente y la clave privada no está comprometida, es extremadamente difícil para alguien imitarla o falsificarla.	***

El software acepta argumentos del usuario que especifica qué comando de programa les gustaría que ejecutara el sistema. ¿De qué tipo de vulnerabilidad estamos hablando?	Inyección de Comandos de Sistema Operativo	El usuario puede proporcionar argumentos que se ejecutan como comandos del sistema operativo, lo que puede llevar a una inyección de comandos. Este tipo de vulnerabilidad es peligroso porque permite a los atacantes ejecutar comandos arbitrarios en el sistema, lo que puede llevar a la ejecución de acciones no autorizadas o incluso a comprometer todo el sistema.
¿Cómo se denomina al proceso de transformación de los datos que proporciona el usuario antes de procesarlos?	Sanitización	Al sanitizar los datos, se eliminan caracteres especiales, se escapan las cadenas peligrosas y se valida que los datos cumplan con ciertos criterios antes de ser procesados. Esto ayuda a garantizar que los datos sean seguros y confiables, reduciendo así el riesgo de que un atacante pueda aprovecharse de las vulnerabilidades del sistema a través de la entrada de datos no seguros.
Es recomendable monitorear las bases de datos de seguimiento de errores y las listas de divulgación de vulnerabilidades para determinar si su aplicación está en riesgo. ¿Lo anterior es una técnica de mitigación para cuál de las siguientes categorías de vulnerabilidades?	Vulnerable and Outdated Components	Monitorear las bases de datos de seguimiento de errores y las listas de divulgación de vulnerabilidades es una forma efectiva de identificar vulnerabilidades en los componentes de software utilizados en una aplicación. Al mantenerse actualizado sobre las vulnerabilidades conocidas en los componentes de software, las organizaciones pueden tomar medidas proactivas para parchear o actualizar estos componentes, reduciendo así el riesgo de explotación de vulnerabilidades en la aplicación.
Casi cualquier fuente que acepte datos es un vector de inyección potencial si los datos no se validan antes de su procesamiento	VERDADERO	Casi cualquier fuente que acepte datos, como formularios web, campos de búsqueda, parámetros de URL, etc., puede convertirse en un vector potencial de inyección si los datos no se validan adecuadamente antes de su procesamiento. La inyección de código malicioso, como la inyección SQL o la inyección de comandos, puede ocurrir si los datos no se manejan de manera segura y no se valida su integridad. Por lo tanto, es fundamental validar y sanitizar todos los datos recibidos por una aplicación para prevenir posibles ataques de inyección.
La instalación de software con usuarios y contraseñas por defecto, uso de puertos y protocolos innecesarios, páginas no utilizadas, así como archivos y directorios no protegidos permite la ejecución de ataques basados en la siguiente categoría de vulnerabilidades.	Security Misconfiguration	La configuración incorrecta de sistemas, software o servicios puede dejar expuestos diversos aspectos del sistema, como usuarios y contraseñas por defecto, puertos y protocolos innecesarios, páginas no utilizadas, así como archivos y directorios no protegidos. Estas configuraciones erróneas pueden ser explotadas por los atacantes para comprometer la seguridad del sistema.
Se trata de un tipo de ataque que aprovecha fallas de seguridad en sitios web y que permite a los atacantes implantar scripts maliciosos en un sitio web legítimo (también víctima de atacante) para ejecutar un script en el navegador de un usuario desprevenido que visita dicho sitio y afectarlo, ya sea robando credenciales, redirigiendo al usuario a otro sitio malicioso, o para realizar defacement en un sitio web. ¿Cómo se denomina este tipo de ataques?	Cross-Site Scripting (XSS)	Es un tipo de ataque que permite a los atacantes insertar scripts maliciosos en páginas web vistas por otros usuarios. Estos scripts pueden ejecutarse en el navegador del usuario desprevenido cuando visita la página web comprometida, lo que puede conducir a una variedad de acciones maliciosas, como robo de credenciales, redirecciones a sitios maliciosos o defacement del sitio web.

Complete la siguiente oración: Los _____ no solo ayudan con las investigaciones forenses como control de detección, sino que también se pueden usar para solucionar errores y excepciones, si las acciones del software se rastrean adecuadamente.	Requerimientos de Integridad	Los requerimientos de seguimiento se refieren a la capacidad de registrar y rastrear las acciones realizadas por el software, lo que puede ser útil para diversos propósitos, como la solución de problemas, la mejora del rendimiento y la investigación forense.
Los lenguajes de programación han evolucionado para desarrollar sistemas operativos, software y programas con protecciones de desbordamiento incorporadas.	VERDADERO	Muchos lenguajes modernos como Java, C#, Python y Rust, entre otros, proporcionan mecanismos de gestión de memoria automática que ayudan a prevenir los desbordamientos de búfer y otras formas de corrupción de memoria. Además, los compiladores y herramientas de desarrollo también han mejorado para detectar y prevenir potenciales vulnerabilidades relacionadas con desbordamientos durante el proceso de desarrollo.
¿Cómo se denomina a las interfaces que se utilizan para configurar y administrar la seguridad dentro del software?	Security Management Interfaces (SMI)	Están diseñadas específicamente para permitir a los administradores de sistemas configurar y administrar las políticas de seguridad, los permisos de acceso, la autenticación y otros aspectos relacionados con la seguridad dentro del software o del sistema en general.
En el contexto de software seguro, la administración de los parámetros de configuración, significa que los parámetros que componen el software se gestionan y protegen, para que sean menos	VERDADERO	La administración de los parámetros de configuración implica gestionar y proteger los diversos parámetros que componen el software para reducir la probabilidad de explotación. Esto incluye la configuración adecuada de parámetros relacionados con la seguridad, como opciones de cifrado, configuraciones de autenticación, permisos de acceso y otros ajustes relevantes.
Esto es particularmente más frecuente en el software adquirido a través de la cadena de suministro y en el desarrollo de software de código abierto, en el que el personal no desarrolla todos los componentes de la aplicación, bajo el estricto control de la empresa. ¿Lo anterior describe a que categoría de amenazas?	Vulnerable and Outdated Components	La utilización de software adquirido a través de la cadena de suministro o el desarrollo de software de código abierto pueden exponer a una organización a riesgos relacionados con componentes vulnerables o desactualizados. Estos riesgos pueden surgir debido a vulnerabilidades presentes en los componentes utilizados, que pueden ser explotadas por atacantes.
¿A qué principio de seguridad se refiere el uso de zonas que separan los diferentes niveles de acceso según la zona a la que el software o la persona está autorizada para acceder?	Separación de Responsabilidades	Al establecer zonas de acceso separadas y restringir el acceso según los niveles de autorización, se garantiza que cada entidad tenga acceso solo a los recursos y datos necesarios para cumplir con sus responsabilidades específicas.
¿Cuáles de los siguientes elementos son parte del diseño de la memoria interna de un programa?	Stack y Heap	La pila (stack) y el montículo (heap) son áreas de memoria importantes en el diseño de la memoria interna de un programa. La pila se utiliza para almacenar variables locales y datos de control de las funciones, mientras que el montículo se utiliza para la asignación dinámica de memoria durante la ejecución del programa. Estas dos áreas de memoria son esenciales para el funcionamiento y la gestión de la memoria en un programa.

¿A que categoría de vulnerabilidades nos referimos cuando un usuario o alguien ajeno obtiene por diversos medios (ataques de fuerza bruta u otros ataques automatizados, acceso al almacenamiento de las contraseñas que se encuentran en texto claro o utilizan funciones de hash débiles, exposición del identificador de sesión en la URL, etc.) una contraseña de otro usuario o miembro de la empresa, suplantando su identidad?	Identification and Authentication Failures	Este tipo de vulnerabilidad ocurre cuando fallan los mecanismos de identificación y autenticación de un sistema, lo que permite que un usuario malintencionado obtenga acceso no autorizado al sistema o a los recursos protegidos. En el escenario descrito, la suplantación de identidad se produce como resultado de una falla en los controles de autenticación, como contraseñas débiles, almacenamiento inseguro de contraseñas o exposición del identificador de sesión en la URL, lo que permite a un atacante obtener acceso a las credenciales de otro usuario y utilizarlas para hacerse pasar por esa persona.	**
¿Qué tipo de malware permanece oculto (en modo sigiloso) y opera subrepticamente, a menudo sin el conocimiento o el consentimiento del sistema o usuario victimizado?	Stealthware	Este tipo de malware está diseñado para operar de manera sigilosa y evadir la detección por parte de los usuarios y las soluciones de seguridad. Su objetivo principal es recopilar información, robar datos, o permitir el control remoto del sistema infectado sin ser detectado. El término "Stealthware" deriva de "stealth", que significa sigilo u ocultamiento.	
Implemente el número máximo de intentos de autenticación permitido y cuando haya pasado ese número se debe denegar de forma predeterminada y desactivar (bloquear) la cuenta durante un periodo de tiempo específico o hasta que el usuario siga un proceso fuera de banda para reactivar (desbloquear) la cuenta. ¿Lo anterior es una técnica de mitigación para cuál categoría de vulnerabilidades?	Identification and Authentication Failures	Al limitar el número de intentos de autenticación y bloquear la cuenta después de un número máximo de intentos fallidos, se protege contra ataques de fuerza bruta y otros intentos de comprometer las credenciales de un usuario. Esta técnica ayuda a fortalecer la autenticación del sistema y a proteger contra accesos no autorizados.	*
El hecho de que el código se compile sin ningún error, que pueda analizarse mediante el análisis de código estático, significa que se ejecutará sin ningún error.	FALSO	El hecho de que el código se compile sin ningún error y pase el análisis de código estático no garantiza que se ejecutará sin ningún error. El análisis de código estático puede ayudar a identificar posibles problemas en el código, como vulnerabilidades de seguridad o errores de programación, pero no puede detectar todos los posibles problemas.	
Se recomienda como una mejor práctica redirigir los errores y las excepciones a una ubicación de manejo de errores personalizada y predeterminada y, según el contexto de inicio de sesión del usuario (remoto o local), se pueden mostrar los detalles de los mensajes apropiados.	VERDADERO	Redirigir los errores y las excepciones a una ubicación de manejo de errores personalizada y predeterminada es una buena práctica en el desarrollo de software. Esto ayuda a centralizar el manejo de errores, lo que facilita la identificación y la resolución de problemas en el sistema. Además, según el contexto de inicio de sesión del usuario (remoto o local), se pueden mostrar mensajes de error apropiados para brindar una experiencia más útil y segura al usuario.	
¿Cuál de las siguiente características tiene que ver con mantener la privacidad de los datos?	Confidencialidad	La confidencialidad se refiere a la protección de la información sensible y su acceso solamente por aquellos usuarios autorizados. Mantener la confidencialidad de los datos es fundamental para preservar la privacidad de la información y prevenir accesos no autorizados.	
¿En qué categoría de vulnerabilidades se describe a la ausencia de actualizaciones y parches de seguridad en el sistema operativo y software instalado como una de las causas de su existencia?	Security Misconfiguration	La falta de actualizaciones y parches de seguridad puede considerarse como una configuración insegura del sistema, ya que no se está manteniendo adecuadamente para proteger contra las vulnerabilidades conocidas.	**

¿Cuáles de los siguientes requerimientos responden a la pregunta de qué se permite o no hacer?	Requerimientos de Autorización	Establecen quién tiene permiso para acceder a qué recursos y qué acciones pueden realizar una vez que han obtenido acceso. Estos requerimientos definen los límites y los derechos de los usuarios dentro del sistema. Por lo tanto, son los que determinan qué se permite o no hacer en el sistema en términos de acceso y operaciones.
¿Qué práctica proporciona al equipo de desarrollo de software un punto de vista del atacante o del usuario hostil?	Pruebas de Seguridad	Es una técnica utilizada en seguridad informática para identificar y documentar posibles amenazas que podrían afectar un sistema. Este proceso implica considerar los puntos de vista de los atacantes o usuarios hostiles y anticipar cómo podrían intentar comprometer la seguridad del sistema. Al desarrollar un modelo de amenazas, el equipo de desarrollo puede comprender mejor los posibles escenarios de amenazas y tomar medidas proactivas para mitigar los riesgos identificados.
Cuando se van a utilizar componentes que no se desarrollaron bajo su control, es importante asegurarse de que los componentes y sus versiones, incluidas las dependencias, no solo se identifiquen primero (se conozcan), sino que también se mantengan actualizados. ¿Lo anterior es una técnica de mitigación para cuál de las siguientes categorías de vulnerabilidades?	Vulnerable and Outdated Components	Esta técnica se enfoca en asegurarse de que los componentes de software utilizados, incluyendo sus versiones y dependencias, se conozcan y se mantengan actualizados para evitar el uso de componentes obsoletos o vulnerables que puedan introducir riesgos de seguridad en el sistema. Por lo tanto, es una medida destinada a abordar la categoría de vulnerabilidades relacionadas con componentes desactualizados y vulnerables.
¿Cuáles son algunas de las responsabilidades del Custodio de los Datos?	Realizar el ejercicio de clasificación de información. Realizar copias de seguridad y recuperación según lo especificado por el propietario de los datos.	El Custodio de los Datos es responsable de implementar prácticas para la protección y gestión adecuada de los datos, lo que incluye clasificar la información de manera adecuada, realizar copias de seguridad y recuperación de datos según las especificaciones del propietario de los datos. Estas responsabilidades aseguran la integridad, confidencialidad y disponibilidad de la información gestionada por el Custodio de los Datos.
El uso de algoritmo criptográfico no validado, desarrollado a medida o débil, es un ejemplo de vulnerabilidad criptográfica	VERDADERO	Los algoritmos criptográficos deben ser robustos y estar ampliamente aceptados por la comunidad de seguridad antes de ser utilizados en aplicaciones críticas. El uso de algoritmos no validados o débiles puede exponer los datos a riesgos de ataques criptográficos y comprometer la seguridad de la información. Por lo tanto, es importante utilizar algoritmos criptográficos sólidos y validados para proteger la confidencialidad e integridad de los datos.
La firma digital que se utiliza para firmar un mensaje no puede ser fácilmente imitada por alguien a menos que esta se vea comprometida	VERDADERO	Una firma digital se utiliza para garantizar la autenticidad e integridad de un mensaje. Si una firma digital se implementa y gestiona correctamente, es extremadamente difícil de imitar sin comprometer la clave privada asociada. La clave privada se utiliza para firmar el mensaje y generar la firma digital, y solo el propietario de esa clave privada debería tener acceso a ella. Si la clave privada no se ve comprometida, la firma digital resultante es confiable y difícil de falsificar. Por lo tanto, la afirmación es verdadera.

"Un agente intencionalmente causa que una nueva amenaza suceda" ¿Qué concepto describe el enunciado anterior?	Ataque	Es un acto deliberado de un agente que busca explotar una vulnerabilidad o debilidad en un sistema para comprometer su seguridad, causar daño o robar información. En este caso, el agente intencionalmente causa que ocurra una nueva amenaza mediante un acto de ataque.
Cuando trabajamos con contenedores se recomienda que las imágenes del contenedor estén firmadas y provengan de fuentes confiables.	VERDADERO	La firma de las imágenes del contenedor ayuda a garantizar su autenticidad e integridad, lo que significa que las imágenes no han sido alteradas y que provienen de la fuente esperada. Esto ayuda a proteger contra posibles ataques de suplantación de identidad y garantiza que el software en ejecución sea seguro y confiable.
Solo porque las credenciales de una entidad fueron validadas, no significa que tenga acceso a todos los recursos que solicite. ¿Cómo se conoce al proceso de validar los derechos y privilegios?	Autorización	Es una fase posterior a la autenticación, que verifica la identidad de la entidad. Una vez autenticada, la autorización determina qué recursos específicos puede acceder o utilizar la entidad, basándose en sus roles, permisos y políticas de seguridad establecidas.
"No confiar en - Seguridad mediante obscuridad", ¿A cuál principio de seguridad se refiere el enunciado anterior?	Diseño Abierto	La seguridad debe ser alcanzada a través de la transparencia, donde los detalles de implementación son públicos y abiertamente disponibles para su escrutinio por parte de expertos. Este enfoque ayuda a identificar y corregir vulnerabilidades de manera más efectiva, en lugar de depender únicamente del secreto para proteger un sistema.
¿Cómo se denomina al mecanismo de seguridad que evita que el software que se ejecuta en un sistema acceda al sistema operativo host?	Sandboxing	Es una técnica de seguridad que restringe el acceso de un programa o proceso a determinados recursos del sistema, como archivos, red, memoria, entre otros. Esto se logra ejecutando el programa en un entorno controlado y limitando sus capacidades para evitar daños o intrusiones en el sistema operativo host.
Complete la siguiente oración: Los _____, ayudan a identificar los requisitos de seguridad al modelar escenarios negativos.	Casos de Abuso	Son una técnica utilizada en la ingeniería de requisitos de seguridad para identificar posibles escenarios de ataque o abuso contra un sistema. Ayudan a comprender cómo un atacante podría intentar comprometer la seguridad del sistema y permiten a los diseñadores y desarrolladores tomar medidas proactivas para mitigar estos riesgos. Por lo tanto, los casos de abuso son herramientas valiosas para identificar requisitos de seguridad al modelar escenarios negativos.
¿Mediante qué elemento se da la comunicación entre los componentes de la CPU?	Buses	Son los canales de comunicación que permiten la transferencia de datos entre los diferentes componentes de la CPU, como la unidad de control, la unidad aritmética lógica y la memoria. Hay varios tipos de buses, como el bus de datos, el bus de direcciones y el bus de control, que se utilizan para diferentes propósitos en el procesador.
¿Cuál de los siguientes es un ejemplo de fuente interna para definir requerimientos de seguridad?	Políticas de Seguridad	Son directrices internas establecidas por una organización para garantizar la seguridad de la información y los sistemas. Estas políticas pueden incluir normas, procedimientos y prácticas que regulan el comportamiento de los empleados, el uso de recursos de TI y la protección de datos confidenciales. Por lo tanto, son una fuente interna para definir los requerimientos de seguridad dentro de una organización.

*

¿ A qué categoría de amenazas pertenece la siguiente descripción?. A pesar de la existencia de un control de autenticación debidamente implementado, un atacante podría hacer uso de ataques que manipulen encabezados o directivas de seguridad que no se encuentren debidamente configuradas en búsqueda de errores que revelen rastros de pila u otros mensajes de error con información confidencial, permitiéndole al atacante utilizar estos datos para intentar llevar a cabo el acceso al sistema o un robo de la información almacenada en él.	Security Misconfiguration	Esta categoría de amenazas se refiere a situaciones en las que los controles de seguridad, como la autenticación, están presentes pero no se implementan correctamente o se configuran de manera inadecuada. En el caso descrito, a pesar de que existe un control de autenticación adecuado, el atacante puede aprovechar la configuración incorrecta o insuficiente de los encabezados HTTP o las directivas de seguridad para acceder a información confidencial, como rastros de pila o mensajes de error detallados, que podrían ser utilizados para llevar a cabo ataques adicionales, como el acceso no autorizado al sistema o el robo de información.	*
Completa la siguiente oración: La metodología_____ sirve para clasificar el riesgo de la amenaza calculando el promedio de los valores numéricos asignados a las categorías de clasificación de riesgo	DREAD	La metodología DREAD proporciona una puntuación de riesgo que ayuda a priorizar las medidas de mitigación y la asignación de recursos para abordar las amenazas más críticas y urgentes. Por lo tanto, al calcular el promedio de los valores numéricos asignados a las categorías de clasificación de riesgo, la metodología DREAD ofrece una justificación lógica y cuantitativa para la evaluación y gestión del riesgo de seguridad en un sistema de información.	
Los_____ son bytes aleatorios que se pueden usar con la función hash para evitar colisiones y prevenir ataques de diccionario preconstruidos.	Salt Values	Son bytes aleatorios que se pueden utilizar con la función hash para evitar colisiones y prevenir ataques de diccionario preconstruidos. Al añadir una sal única a cada entrada, incluso entradas idénticas producirán valores hash diferentes. Esto dificulta la creación de tablas de hash precalculadas (ataques de diccionario) y mejora la seguridad de las contraseñas almacenadas en las bases de datos. La sal se almacena típicamente junto con la contraseña cifrada o hasheada, y se utiliza durante la autenticación para verificar la contraseña del usuario.	
Complete la siguiente oración: La_____ se puede realizar alterando el orden de las instrucciones de ejecución del programa, cambiando el gráfico de control mediante la inserción de instrucciones de salto arbitrarias.	Ofuscación de flujo de código	Consiste en modificar el flujo lógico y la estructura del programa de manera que el código resultante sea más difícil de entender para los humanos, pero siga funcionando de la misma manera. Una de las formas de lograr esto es reorganizando el orden de las instrucciones o introduciendo instrucciones adicionales que cambien el flujo de ejecución del programa de una manera no intuitiva. Esto puede dificultar la ingeniería inversa y la comprensión del código por parte de los atacantes, lo que puede ayudar a proteger el software contra análisis malintencionados y ataques de piratería.	**
¿Qué algoritmos criptográficos son muy rápidos y eficientes en el cifrado de grandes volúmenes de datos en un periodo corto de tiempo?	Algoritmos Simétricos	Utilizan una sola clave para cifrar y descifrar datos. Debido a su diseño, son más rápidos y eficientes en términos de rendimiento en comparación con los algoritmos asimétricos (también conocidos como algoritmos de clave pública), que requieren operaciones más complejas y computacionalmente costosas.	*
Complete la siguiente oración: En una_____, los atacantes explotan la forma en que se construyen las consultas de la base de datos en una aplicación.	Inyección SQL	Es una técnica común de ataque en la que los atacantes insertan código SQL malicioso en las entradas de un formulario web u otros parámetros de una aplicación que luego se envían a la base de datos para su procesamiento. Si la aplicación no valida o filtra adecuadamente estas entradas, el código SQL malicioso puede ser ejecutado por la base de datos, lo que permite a los atacantes llevar a cabo una variedad de acciones maliciosas, como la eliminación de datos, la obtención de información confidencial o la manipulación de la base de datos.	*****

"Los mensajes de error que se muestran al usuario final revelarán solo la información necesaria sin revelar ningún detalle del sistema interno." ¿De qué tipo de requerimiento es ejemplo el enunciado anterior?	Requerimiento de manejo de errores	Se refieren a las especificaciones que dictan cómo debe comportarse el sistema cuando se producen errores o excepciones durante su ejecución. En este caso específico, el requerimiento establece que los mensajes de error mostrados al usuario final deben ser informativos pero sin revelar detalles sensibles o internos del sistema. Esto es importante para mantener la seguridad y la privacidad de los datos, así como para evitar que los usuarios finales accedan a información que podría ser utilizada por atacantes para comprometer el sistema.	**
¿Cuándo programamos en lenguaje ensamblador es un ejemplo de uso de lenguajes de qué nivel?	Bajo Nivel	Son aquellos que tienen una correspondencia más directa con la arquitectura y el funcionamiento interno del hardware de la computadora. El lenguaje ensamblador es un lenguaje de programación de bajo nivel que utiliza representaciones mnemónicas de las instrucciones del procesador y las direcciones de memoria para escribir programas. Cada instrucción en lenguaje ensamblador se traduce directamente en una instrucción de máquina específica que el procesador puede ejecutar.	**
Los datos o la información pueden considerarse el activo más valioso que tiene una empresa, solo superado por su personal	VERDADERO	Los datos o la información pueden considerarse como uno de los activos más valiosos que tiene una empresa, y en muchos casos son considerados el activo más valioso, solo superados por el capital humano o el personal. La información es fundamental para el funcionamiento y el éxito de una empresa en diversos aspectos, incluyendo la toma de decisiones estratégicas, la planificación de negocios, la gestión de clientes, la innovación, entre otros.	
Complete la siguiente oración: Las metodologías____ se basan en el desarrollo iterativo con el objetivo de minimizar la tasa de fallos del proyecto de desarrollo de software.	Desarrollo Ágil	El enfoque ágil se centra en la entrega continua de software funcional en ciclos cortos de desarrollo llamados iteraciones o sprints. Durante cada iteración, se desarrolla, prueba y se entrega una parte del software funcional al cliente. Esta metodología permite una retroalimentación rápida y continua, lo que facilita la detección temprana de errores y la capacidad de realizar ajustes rápidos en función de los comentarios del cliente.	
¿En qué categoría de vulnerabilidades se describe que la presencia de software con cuentas y/o configuraciones por defecto afectan la seguridad sistema donde ha sido instalado?	Security Misconfiguration	Esta categoría de vulnerabilidades se refiere a la falta de configuración adecuada de los controles de seguridad en el software, sistemas o aplicaciones. En el caso de software que viene con cuentas o configuraciones por defecto, esto puede permitir que los atacantes exploten fácilmente el sistema si no se cambian estas configuraciones predeterminadas. Los atacantes pueden aprovechar estas cuentas o configuraciones débiles para acceder sin autorización, comprometer el sistema o realizar otras acciones maliciosas.	
¿Cuál de los siguientes factores no forma parte del denominado triángulo de hierro, en la administración de proyectos de desarrollo de software?	Seguridad	El triángulo de hierro en la gestión de proyectos de software generalmente se refiere a tres factores principales: alcance, tiempo y costo. Estos tres factores están interrelacionados y representan las restricciones básicas que enfrenta cualquier proyecto de desarrollo de software. La idea es que hacer cambios en uno de estos factores afectará a los otros dos.	*
¿Qué técnica de sanitización reemplaza las entradas proporcionadas por el usuario con alternativas más seguras?	Literalización	En la técnica de escape, se identifican caracteres especiales o potencialmente peligrosos en la entrada del usuario y se reemplazan con secuencias de escape o se eliminan para hacer que la entrada sea segura antes de procesarla o mostrarla en una aplicación web.	*

¿Cuál de las siguientes características tiene que ver con mantener la privacidad de los datos?	Confidencialidad	La confidencialidad se refiere a la protección de la información sensible para que solo aquellos que están autorizados tengan acceso a ella. Esto implica asegurar que los datos sensibles no sean revelados o accedidos por personas no autorizadas, ya sea de manera intencionada o accidental. Mantener la confidencialidad de los datos es fundamental para proteger la privacidad de los individuos y evitar la divulgación no autorizada de información confidencial.
Utilice las propiedades innerText de los controles HTML en lugar de la propiedad innerHTML al almacenar la entrada proporcionada. ¿Lo anterior es una técnica de mitigación para qué tipo de vulnerabilidad?	Cross-Site Scripting (XSS)	es una vulnerabilidad de seguridad que permite a los atacantes inyectar scripts maliciosos en páginas web vistas por otros usuarios. Estos scripts pueden ser utilizados para robar cookies de sesión, redirigir a sitios falsos o modificar el contenido de la página. Una de las formas de explotar esta vulnerabilidad es mediante la inserción de código JavaScript dentro de los datos ingresados por el usuario, que luego se ejecuta en el navegador del usuario final.
¿Qué tipo de malware actúa imponiendo restricciones a la víctima que infecta y exige que se pague un rescate para eliminar la restricción?	Ransomware	Este tipo de malware cifra los archivos o bloquea el acceso al sistema de la víctima y luego solicita un rescate, generalmente en forma de criptomonedas, a cambio de proporcionar la clave de descifrado o restaurar el acceso al sistema.
¿Qué método funciona, cuando el que tiene el punto de vista opuesto es cuestionado sobre su razón de ser, a menudo con una forma negativa de su propia pregunta?	Método Socrático	Este método, nombrado en honor al filósofo griego Sócrates, implica cuestionar al interlocutor sobre sus creencias o argumentos mediante una serie de preguntas, a menudo utilizando una forma negativa de la pregunta original, con el fin de examinar la coherencia y la validez de sus ideas.
La incorporación de características de seguridad da como resultado: un software muy complejo, restrictivo y difícil de utilizar	FALSO	La incorporación de características de seguridad no necesariamente resulta en un software muy complejo, restrictivo y difícil de utilizar. Si bien es cierto que algunas medidas de seguridad pueden agregar complejidad al software y pueden requerir cierto nivel de restricción para garantizar la protección adecuada, esto no significa que todo el software con características de seguridad sea intrínsecamente difícil de usar. De hecho, es posible diseñar e implementar medidas de seguridad de manera que proporcionen un equilibrio adecuado entre la seguridad y la facilidad de uso. Esto implica considerar las necesidades y expectativas de los usuarios finales, así como implementar controles de seguridad de manera transparente y sin interferir demasiado con la experiencia del usuario.
¿Cuál de las siguientes es la política de seguridad aplicable de forma universal para toda la organización?	Políticas Organizacionales	Las políticas organizacionales establecen los principios generales y las reglas que rigen la seguridad de la información en toda la organización. Estas políticas proporcionan directrices amplias que todos los empleados, contratistas y otros actores dentro de la organización deben seguir en relación con la protección de los activos de información y la mitigación de los riesgos de seguridad. Las políticas organizacionales suelen incluir aspectos como el manejo de contraseñas, el acceso a los sistemas, la privacidad de la información, el uso aceptable de los recursos informáticos y otras áreas relacionadas con la seguridad de la información.

¿Qué principio se asegura que cuando se trabaja con la autorización, el diseño debe garantizar que solo el conjunto mínimo de derechos se otorgue explícitamente al usuario o recurso?	Menor Privilegio	Este principio establece que los usuarios, programas o procesos deben tener solo los privilegios o permisos necesarios para realizar su función específica y no se les deben otorgar privilegios adicionales que no son necesarios. Esto ayuda a reducir la superficie de ataque y minimizar el riesgo de que un usuario o proceso malintencionado cause daño o comprometa la seguridad del sistema.	*
En una CPU quién actúa como mediador y controla las instrucciones de procesamiento	Unidad de Control	La Unidad de Control coordina las operaciones de la CPU, interpretando las instrucciones del programa almacenadas en la memoria y dirigiendo las operaciones necesarias para ejecutar esas instrucciones.	*
Es casi cien veces más costoso corregir errores de seguridad una vez que el software está en producción que cuando se está diseñando	VERDADERO	Esto se debe a que los errores de seguridad descubiertos en la etapa de producción pueden tener un impacto significativo en términos de tiempo, recursos y reputación de la empresa. Corregir estos errores puede requerir la aplicación de parches, actualizaciones de software, mitigación de incidentes de seguridad, pérdida de datos, daños a la reputación de la marca y posibles sanciones regulatorias.	*
¿Qué principio de seguridad también es conocido como Defensa en Capas?	Defensa a Profundidad	Este enfoque de seguridad se basa en la implementación de múltiples capas de controles de seguridad en un sistema o red con el fin de aumentar la protección y mitigar los riesgos de manera más efectiva. Al aplicar la defensa en profundidad, se utilizan diversas medidas de seguridad en diferentes niveles del sistema, lo que dificulta que un atacante comprometa todo el sistema con un solo ataque.	
¿Cuáles de los siguientes son ejemplos de fuentes internas para la definición de requerimientos de seguridad?	Políticas, estándares internos, pautas, patrones y prácticas	Políticas: Establecen las reglas, directrices y principios de seguridad que deben seguirse dentro de una organización. Las políticas de seguridad definen las expectativas y los requisitos de seguridad para los sistemas, datos y usuarios. Estándares internos: Son normas específicas que detallan cómo se deben implementar y mantener los controles de seguridad dentro de una organización. Los estándares internos proporcionan instrucciones detalladas sobre cómo cumplir con las políticas de seguridad de la organización. Pautas: Son recomendaciones o lineamientos menos formales que los estándares, pero que aún ofrecen orientación sobre cómo llevar a cabo ciertas actividades o implementar controles de seguridad de manera efectiva. Patrones: Son soluciones probadas y repetibles para problemas comunes de seguridad. Los patrones de seguridad capturan las mejores prácticas y experiencias pasadas para ayudar a diseñar sistemas seguros y resolver problemas de seguridad de manera efectiva. Prácticas: Se refieren a los métodos y enfoques utilizados por una organización para implementar y mantener la seguridad de la información. Las prácticas de seguridad incluyen procesos, procedimientos y técnicas específicas utilizadas para proteger los activos de información de la organización.	*

Insuficiente protección de datos de movimiento. Insuficiente protección de datos en reposo. Ingeniería social electrónica. ¿Son algunas de las causas principales que permiten la explotación de qué categoría de vulnerabilidades?	Identification and Authentication Failures	Cuando los datos en movimiento o en reposo no están adecuadamente protegidos o cuando se realizan ataques de ingeniería social electrónica para obtener información confidencial, se puede abrir la puerta a explotaciones debido a configuraciones de seguridad deficientes.	*
Se dice que una aplicación web es susceptible a la vulnerabilidad_____ cuando la entrada suministrada por el usuario se envía de vuelta al cliente del navegador sin ser validada adecuadamente.	Cross-Site Scripting	En esta vulnerabilidad, los atacantes inyectan scripts maliciosos (generalmente JavaScript) en páginas web visitadas por otros usuarios. Cuando un usuario legítimo carga la página web comprometida, el código malicioso se ejecuta en su navegador, lo que permite al atacante robar cookies de sesión, redirigir a sitios falsos o modificar el contenido de la página.	
¿Qué tipo de análisis efectúa la inspección del código cuando este se está ejecutando?	Análisis de Código Dinámico	El análisis de código dinámico implica observar y evaluar el comportamiento del código en tiempo de ejecución. Esto puede incluir la detección de errores, la identificación de vulnerabilidades de seguridad, el rendimiento del software, entre otros aspectos. Durante la ejecución, se recopilan datos y métricas que pueden ser utilizados para comprender mejor el comportamiento del software y mejorar su calidad y seguridad.	*****
Complete la siguiente oración: Las_____ hacen que la funcionalidad interna de una función de software sea accesible para las personas externas (otras entidades y funciones de código).	APIs	Son conjuntos de reglas y protocolos que permiten que diferentes componentes de software se comuniquen entre sí. Facilitan la interacción entre aplicaciones y sistemas, permitiendo que diferentes partes del software accedan a las funciones y datos de otras partes de manera controlada y segura.	*****
El control de versiones del software no solo garantiza que el equipo de desarrollo esté trabajando con la versión correcta del código, sino que también brinda la capacidad de retroceder a una versión anterior en caso de que sea necesario.	VERDADERO	El control de versiones del software es una práctica común en el desarrollo de software que implica el seguimiento de los cambios realizados en el código fuente y la documentación asociada a lo largo del tiempo. Además de asegurar que el equipo de desarrollo esté trabajando con la versión correcta del código en un momento dado, el control de versiones también proporciona la capacidad de retroceder a una versión anterior en caso de que sea necesario. Esto es útil en situaciones como la introducción de errores en el código o la necesidad de volver a una versión estable anterior debido a problemas de compatibilidad o funcionales.	*

¿Qué metodología de modelado de amenazas se realiza en la fase de diseño del desarrollo de software agrupando y clasificando las amenazas en seis categorías?	STRIDE	La metodología de modelado de amenazas que se realiza en la fase de diseño del Desarrollo de software, agrupando y clasificando las amenazas en seis categorías, se conoce como STRIDE. STRIDE es un acrónimo que representa las siguientes categorías de amenazas: Spoofing of identity (Suplantación de identidad) Tampering with data (Manipulación de datos) Repudiation (Repudio) Information disclosure (Divulgación de información) Denial of Service (Denegación de servicio) Elevation of privilege (Elevación de privilegios) Estas categorías son utilizadas para identificar y analizar las posibles amenazas y vulnerabilidades durante el proceso de diseño del software, permitiendo a los equipos de desarrollo tomar medidas proactivas para mitigar los riesgos de seguridad.	*
La clasificación de los datos en niveles de sensibilidad se usa para determinar los requisitos de confidencialidad	VERDADERO	Al asignar niveles de sensibilidad a los datos, se puede establecer claramente cuánto cuidado y protección requiere cada tipo de información. Esto permite que las organizaciones implementen medidas de seguridad adecuadas, como controles de acceso, cifrado y políticas de manejo de datos, para garantizar que la información confidencial esté protegida de manera adecuada y proporcional a su nivel de sensibilidad.	**
Los analizadores de código fuente utilizan predominantemente la comparación de patrones con una lista conocida de sintaxis de vulnerabilidades y análisis de flujo / modelo de datos contra conjuntos de datos conocidos para detectar vulnerabilidades.	VERDADERO	Estas técnicas involucran el seguimiento de cómo los datos se mueven y se manipulan a través del código, lo que permite identificar posibles puntos de vulnerabilidad, como la falta de validación de entrada o el uso incorrecto de funciones de seguridad.	
El objetivo principal de la recolección de basura es reducir las pérdidas de memoria, es decir, recuperar objetos de memoria inalcanzables.	VERDADERO	Al recuperar esta memoria, se reduce la cantidad de memoria desperdiciada y se mejora la eficiencia del programa al liberar recursos que ya no son necesarios. Esto ayuda a evitar las pérdidas de memoria y a mantener un uso eficiente de los recursos del sistema.	**
Cuando hablamos acerca de agentes de amenaza humanos. ¿Cómo se denomina al agente que es un usuario común que ejecuta scripts de hackers contra activos corporativos sin comprender el impacto y las consecuencias de sus acciones?	Script Kiddies	Estos individuos suelen carecer de conocimientos técnicos profundos y dependen de herramientas y scripts preexistentes creados por otros para llevar a cabo ataques cibernéticos. A menudo, su motivación es simplemente causar daño, llamar la atención o demostrar habilidades técnicas limitadas.	****

Se recomienda que la entrada se valide tanto en el cliente (frontend) como en el servidor (back-end).	VERDADERO	La validación en el cliente proporciona una experiencia de usuario más rápida al detectar errores antes de enviar los datos al servidor. Sin embargo, la validación en el servidor es fundamental ya que el cliente es potencialmente inseguro y puede ser manipulado por un atacante. La validación en el servidor garantiza que los datos recibidos cumplan con los criterios de seguridad y negocio antes de ser procesados o almacenados, lo que ayuda a prevenir ataques como la inyección de código malicioso o la manipulación de datos. Por lo tanto, es recomendable implementar validación tanto en el cliente como en el servidor para una seguridad óptima de la aplicación.	**
El modelado de casos de uso es otro mecanismo por el cual se pueden determinar los requisitos funcionales y de seguridad del software	VERDADERO	Es una técnica ampliamente utilizada en la ingeniería de software para capturar, analizar y comunicar los requisitos del sistema desde la perspectiva del usuario final. Los casos de uso describen cómo interactúan los actores (usuarios o sistemas externos) con el sistema para lograr ciertos objetivos. Además de capturar los requisitos funcionales del sistema, los casos de uso también pueden utilizarse para identificar requisitos de seguridad al considerar los posibles escenarios de amenazas y cómo el sistema debe comportarse frente a ellos. Por lo tanto, el modelado de casos de uso puede ser un mecanismo efectivo para determinar tanto los requisitos funcionales como los de seguridad del software.	*
La imagen base de contenedor es la más importante por motivos de seguridad, ya que se utiliza como punto de partida desde el que crea imágenes derivadas.	VERDADERO	Es esencial que la imagen base esté bien mantenida, actualizada y segura. Además, una imagen base segura proporciona una base sólida para todas las imágenes derivadas, lo que ayuda a reducir el riesgo de ataques y compromisos de seguridad en el entorno de contenedores.	
Complete la siguiente oración: Los ____ proporcionan información sobre las amenazas que pueden ocurrir contra el sistema o el software.	Casos de Abuso	Se refieren a escenarios hipotéticos o reales en los que se explotan vulnerabilidades para llevar a cabo ataques o comprometer la seguridad de un sistema. Estos casos de abuso ayudan a los desarrolladores y profesionales de seguridad a comprender mejor las posibles amenazas y a diseñar medidas de protección más efectivas.	
¿Cómo se denomina a malhechores altamente calificados que se les paga profesionalmente por usar sus habilidades para frustrar la protección de seguridad de software y sistemas, buscando una alta ganancia financiera? ¿A qué tipo de agente de amenaza humana corresponde la descripción anterior?	Ciberdelincuentes Organizados	Estos son individuos o grupos altamente calificados que utilizan sus habilidades para llevar a cabo actividades delictivas en línea, como la infiltración en sistemas informáticos, el robo de datos, el fraude financiero y otras actividades ilícitas con el fin de obtener ganancias financieras. Los ciberdelincuentes organizados a menudo tienen una estructura jerárquica, roles definidos y pueden estar respaldados por recursos considerables, lo que les permite llevar a cabo ataques sofisticados y coordinados contra objetivos específicos.	*****
Complete la siguiente oración: _____ se refieren a defectos y arquitectura que pueden dar lugar a defectos de seguridad.	Vulnerabilidades	Al identificar y corregir las vulnerabilidades, se puede mejorar significativamente la seguridad de un sistema, ya que se reduce la superficie de ataque disponible para los adversarios.	
¿Qué tipo de malware se usa principalmente para control remoto o para escuchas de software?	Spyware	El spyware es más específico en su capacidad para recopilar información sin el conocimiento del usuario y puede incluir funcionalidades de escucha, como la captura de teclas, grabación de audio, captura de pantalla, etc.	

Sin los controles de confidencialidad adecuados, el software puede tener fugas de información sobre su configuración, estado y composición interna que un atacante puede usar para robar información o lanzar más ataques. ¿Lo anterior es un ejemplo de qué categoría de vulnerabilidades?	Security Misconfiguration	La falta de controles de confidencialidad adecuados podría permitir fugas de información sobre la configuración, estado y composición interna del software, lo que podría ser aprovechado por un atacante para robar información o lanzar más ataques. Es importante realizar una configuración adecuada de la seguridad para proteger los sistemas y aplicaciones contra este tipo de vulnerabilidades.	*****
Las vulnerabilidades en esta categoría podrían permitir que un atacante obtenga el control de una sesión, pueda interponerse en el medio y hacerse pasar por usuarios válidos y legítimos para las partes que participan en las transacciones de la sesión activa. ¿A qué categoría de vulnerabilidades hace referencia lo antes descrito?	Identification and Authentication Failures	La descripción menciona la posibilidad de que un atacante obtenga el control de una sesión, lo que implica que puede acceder a recursos protegidos sin la debida autenticación. Además, el atacante puede "interponerse en el medio" y hacerse pasar por un usuario legítimo, lo que sugiere que hay una falla en los controles de autorización que deberían impedir este tipo de actividad maliciosa. En conjunto, estos indicadores apuntan a problemas relacionados con la identificación y autenticación de los usuarios, lo que corresponde a la categoría de "Identification and Authentication Failures" dentro del ámbito de las vulnerabilidades de seguridad informática.	*
Complete la siguiente oración: Se sabe que los empleados descontentos que se sienten agraviados por sus empleadores implantan_____ en su código como un medio de venganza contra sus empleadores.	Bombas lógicas	Es un fragmento de código malicioso que se inserta en un software por parte de un programador con acceso privilegiado, como un empleado descontento. Esta bomba lógica está diseñada para activarse en ciertas condiciones específicas, como una fecha o evento particular. Una vez activada, la bomba lógica puede causar daños al sistema, como la eliminación o corrupción de datos, interrupción de servicios, o cualquier otro tipo de sabotaje. Por lo tanto, este tipo de acción se considera una forma de venganza o retaliación por parte del empleado descontento hacia su empleador.	**
Mantener el sistema operativo actualizado con los últimos parches de seguridad proporcionados por el fabricante, además de fortalecer las aplicaciones que se ejecutan sobre estos sistemas operativos, es una recomendación que mitiga la siguiente categoría de vulnerabilidades.	Security Misconfiguration	La actualización del sistema operativo y la aplicación de parches de seguridad ayuda a corregir vulnerabilidades conocidas en el software subyacente, lo que contribuye a prevenir ataques que podrían aprovecharse de esas vulnerabilidades para comprometer la seguridad del sistema. Además, fortalecer las aplicaciones para que funcionen de manera segura sobre estos sistemas operativos también ayuda a evitar configuraciones inseguras o prácticas de desarrollo que podrían exponer el sistema a riesgos de seguridad.	*****
¿Cuál de los siguientes proporciona el punto de vista de los usuarios hostiles?	Casos de Abuso	También conocidos como abusos de uso o mal uso, son escenarios que describen cómo un usuario malintencionado puede intentar explotar una vulnerabilidad en un sistema o aplicación con el fin de comprometer su seguridad. Estos casos ayudan a identificar posibles amenazas y a comprender cómo podrían ser utilizadas por un atacante.	
Complete la siguiente oración: Un ____ es la condición que ocurre cuando los datos que se copian en el búfer (espacio de almacenamiento contiguo asignado en la memoria) son más grandes de lo que el búfer puede manejar.	Buffer Overflow	Cuando esto sucede, los datos adicionales sobrescriben las áreas adyacentes de memoria, lo que puede causar comportamientos inesperados o fallos en el programa. Esta situación puede ser aprovechada por atacantes para ejecutar código malicioso o para alterar el flujo de ejecución del programa de manera no autorizada, lo que potencialmente lleva a la toma de control del sistema.	**

"El balance entre proteger los activos de TI y el costo de implementación de los controles de seguridad de software, de tal forma que el riesgo sea manejado de forma apropiada." ¿A qué principio se refiere el enunciado anterior?	Administración de Riesgos	Implica identificar, evaluar y mitigar los riesgos de seguridad de manera que el riesgo sea manejado de manera apropiada y acorde con los recursos y las necesidades de la organización. Esto puede implicar tomar decisiones informadas sobre cómo asignar recursos para implementar controles de seguridad y proteger los activos críticos de la organización, teniendo en cuenta los costos y beneficios asociados.	*
Esforzarse por la simplicidad. Manteniendo simples mecanismos de seguridad asegura que la implementación no sea parcial, lo que podría resultar en cuestiones de compatibilidad. ¿A qué se refiere el enunciado anterior?	Economía de Mecanismos	Es un principio de seguridad que establece que los mecanismos de seguridad deben ser simples y directos. Mantener los mecanismos de seguridad simples ayuda a reducir la complejidad del sistema y, por lo tanto, disminuye la probabilidad de errores y fallos de implementación. Además, la simplicidad facilita la comprensión y auditoría de los sistemas de seguridad, lo que a su vez mejora la confiabilidad y la eficacia general de los controles de seguridad.	*
¿Cuál de los siguientes es un ejemplo de un activo intangible?	Reputación	La reputación es un ejemplo claro de un activo intangible, ya que representa la percepción pública de una empresa, su marca y sus productos o servicios. Aunque no se puede medir o cuantificar de la misma manera que los activos tangibles como los servidores o las redes, la reputación puede tener un impacto significativo en el éxito y la longevidad de una organización.	
"El archivo de configuración de la aplicación web debe cifrar configuraciones confidenciales de conexiones de bases de datos y otras aplicaciones sensibles." ¿De qué tipo de requerimiento es un ejemplo de enunciado anterior?	Requerimientos de manejo de configuraciones	Este tipo de requerimiento se refiere a la necesidad de proteger y cifrar configuraciones confidenciales de la aplicación, como las credenciales de conexión a bases de datos u otras aplicaciones sensibles. Al cifrar estas configuraciones, se asegura que los datos confidenciales estén protegidos en reposo, lo que ayuda a prevenir el acceso no autorizado a dicha información. Este enfoque es esencial para garantizar la seguridad y la integridad de los datos sensibles manejados por la aplicación web.	*
"No compartir recursos cuando no sea necesario." ¿De qué principio de seguridad estamos hablando?	Mecanismo menos común	Este principio establece que se deben minimizar los puntos de acceso y las áreas de exposición al limitar la cantidad de recursos compartidos o accesibles en un sistema. Al reducir la superficie de ataque, se disminuye la probabilidad de que un atacante pueda encontrar vulnerabilidades y comprometer la seguridad del sistema.	****
¿Cómo se denomina el proceso de combinar las funciones necesarias, las variables y las dependencias, archivos y bibliotecas necesarias para que la máquina ejecute un programa?	Compilación	Se toman los diferentes módulos de un programa que han sido compilados previamente y se combinan para formar un ejecutable final o una biblioteca compartida. Esto implica resolver referencias a funciones y variables, así como manejar la resolución de símbolos y la asignación de direcciones de memoria.	*****
¿A qué principio de seguridad corresponde que los derechos de acceso sean validados cada vez que ocurre un acceso?	Mediación Completa	Implica que cada acceso a un recurso o función debe ser verificado y validado antes de ser permitido. Esto garantiza que los controles de acceso estén presentes en cada punto de acceso y que no se puedan eludir o evadir de manera inadvertida.	**
El costo de corregir software inseguro en etapas tempranas del ciclo de vida de desarrollo de software es significativamente menor, comparado con etapas tardías.	VERDADERO	En las etapas tempranas, los desarrolladores pueden implementar prácticas de seguridad desde el principio, lo que puede incluir diseño seguro, revisión de código, pruebas de seguridad y otros controles preventivos. Esto ayuda a evitar la introducción de vulnerabilidades graves que podrían requerir una reestructuración significativa o incluso el rediseño completo del software en etapas posteriores.	

¿En qué tipo de lenguajes de programación el código fuente no se compila ni se convierte en códigos de instrucciones específicos del procesador?	Lenguajes Interpretados	Los lenguajes interpretados, no se realiza un proceso de compilación que convierta el código fuente en código de máquina específico del procesador. En cambio, el intérprete interpreta y ejecuta las instrucciones directamente desde el código fuente. Esto significa que el código fuente no se compila ni se convierte en códigos de instrucciones específicos del procesador, como sucede en los lenguajes compilados.	****
¿Qué categoría del modelo DREAD clasifica el esfuerzo necesario para manifestar la amenaza y las condiciones previas, si las hay, que son necesarias para materializar la amenaza?	Explotabilidad	Se centra en evaluar cuán fácil sería para un atacante aprovechar una vulnerabilidad para llevar a cabo un ataque. Esto incluye considerar factores como la complejidad del ataque, la disponibilidad de herramientas y conocimientos necesarios, así como cualquier condición previa necesaria para que el ataque tenga éxito.	**
¿Cuál de los siguientes es un documento de conocimiento estándar para desarrolladores y seguridad de aplicaciones web?	OWASP Top 10	Es un documento de conocimiento estándar en la industria para desarrolladores y profesionales de la seguridad de aplicaciones web. Es una lista de las diez vulnerabilidades de seguridad más críticas en aplicaciones web, compilada por la Open Web Application Security Project (OWASP). Este recurso es ampliamente utilizado como referencia para identificar y abordar los problemas de seguridad más comunes en el desarrollo y mantenimiento de aplicaciones web.	****
¿Qué tipo de análisis de código requiere de un entorno simulado que refleje el entorno de producción donde se implementará el código?	Análisis de Código Dinámico	Ofrece una perspectiva más completa al permitir la observación del comportamiento real del software en acción.	
¿Qué vulnerabilidad es considerada una de las debilidades de software (o aplicación) más frecuentes, y ocurren cuando los datos suministrados por el usuario no se validan antes de que un intérprete los procese?	Injection	Esto puede llevar a ataques de inyección, como la inyección de SQL, la inyección de comandos, entre otros, donde un atacante puede insertar código malicioso en las solicitudes de entrada de datos y lograr que el sistema ejecute acciones no deseadas o acceda a datos sin autorización.	*
Complete la siguiente oración: _____ se refieren a defectos de diseño y arquitectura que pueden dar lugar a defectos de seguridad	Vulnerabilidades	Las vulnerabilidades se refieren a debilidades o puntos débiles en el diseño, la implementación o la configuración de un sistema que pueden ser explotadas por un atacante para comprometer la seguridad del sistema. Estas vulnerabilidades pueden surgir debido a defectos de diseño y arquitectura, así como a errores en el código o configuraciones incorrectas. Por lo tanto, las vulnerabilidades son el término más adecuado para completar la oración, ya que son las debilidades que pueden dar lugar a defectos de seguridad.	**
Casi cualquier fuente que acepte datos de un vector de inyección potencial si los datos no se validan antes de su procesamiento.	VERDADERO	Casi cualquier fuente que acepta datos, como entradas de usuario en formularios web, consultas de base de datos, parámetros de URL, etc., puede ser una fuente potencial de inyección si los datos no se validan adecuadamente antes de su procesamiento. La inyección de código es una técnica común de ataque que explota esta falta de validación, permitiendo a los atacantes insertar y ejecutar código malicioso en la aplicación. Por lo tanto, es fundamental realizar una validación adecuada de los datos recibidos para prevenir este tipo de ataques.	
¿A qué categoría de vulnerabilidad corresponde el poder usar un software sin iniciar sesión o hacerse pasar como administrador cuando se inicia sesión con un usuario sin privilegios?	Broken Access Control	Esta categoría de vulnerabilidad se refiere a situaciones en las que un sistema no aplica correctamente las restricciones de acceso, permitiendo a un usuario acceder a recursos o realizar acciones para las cuales no tiene autorización.	****